

Informe Ejecutivo RGPD

Apertura de jornada | Radar regulatorio y de riesgo externo

Fecha:

Estado global: Escenario de cumplimiento medio con tension alta en brechas, transparencia e IA. Riesgos principales - Mayor presion supervisora sobre transparencia e informacion al interesado en 2026. - Rebrote severo de notificaciones de brechas en marzo de 2026, con impacto transversal de encargados. - Mayor exigencia de cumplimiento antes incluso de recabar el dato, por la precision interpretativa del Tribunal Supremo. - Persisten sanciones cuantiosas por fallos de seguridad y notificacion a afectados en telecom y utilities. Recomendacion ejecutiva: Abrir la jornada con una revision combinada de transparencia, brechas y proveedores; es la combinacion de mayor retorno preventivo para una pyme o mediana empresa espanola hoy.	Conclusion rapida - Revisar hoy clausulas informativas, capas de privacidad y trazabilidad de bases juridicas. - Actualizar contratos de encargo y protocolos de brecha para escenarios multi-cliente. - Priorizar DPIA en IA, datos de salud, localizacion, biometria y proveedores criticos. - Validar transferencias internacionales y configuraciones por defecto en SaaS y analitica.
---	--

Estado de Cumplimiento RGPD

Porcentaje global estimado	71%
Nivel	Cumplimiento medio
Evolucion 30 dias	Riesgo al alza
Base metodologica	Valoracion analitica externa

Ligero deterioro del riesgo operativo por mayor foco regulatorio en transparencia y por la intensidad de brechas notificadas.

No es una auditoria interna confirmada. La metrica es una valoracion analitica externa basada en novedades publicas verificadas y obligaciones vigentes.

Riesgo por Area

Area	Nivel	Lectura ejecutiva
Gestion de datos personales	Medio	Presion continua en minimizacion, base juridica y proteccion por defecto
Derechos de los interesados	Alto	El CEF 2026 pone foco directo en transparencia e informacion.
Seguridad de la informacion	Alto	Sanciones recientes por fallos de seguridad y aumento de brechas notifi
Encargados de tratamiento	Alto	AEPD destaca el riesgo de una sola brecha que impacta a multiples resp
Transferencias internacionales	Medio-Alto	Nube, analitica y proveedores USA exigen inventario y garantias actualiz
Documentacion y politicas	Medio	Necesidad de alinear politicas con brechas, IA y transparencia reforzada
Registro de actividades	Medio	Debe reflejar tratamientos previos a la recogida efectiva del dato.
Evaluaciones DPIA	Alto	IA agentica, biometria, salud y localizacion elevan el umbral de riesgo.
Consentimiento	Medio	Especial tension en cookies, marketing y acceso a terminales.

Area	Nivel	Lectura ejecutiva
Cookies	Medio-Alto	La logica ePrivacy sigue siendo critica para tecnologias de seguimiento.
Formacion y concienciacion	Medio-Alto	Phishing, fraude y errores de envio siguen muy presentes en incidentes.
Notificacion de brechas	Alto	La AEPD y el EDPB mantienen foco operacional claro sobre rapidez y c

Incidentes y Brechas Recientes

Fecha	Tipo	Severidad	Descripcion	Datos afectados	Sector	Estado	Accion
2026-05-11	Brecha de datos + sancion	Alta	ICO sanciona a South Staffordshire por datos personales de 663.087 personas en un fichero no autorizado	Datos personales de 663.087 personas	Sanidad	Cerrado oficialmente	Revisar MDR, detección de brechas
2026-04-30	Radar de brechas	Alta	La AEPD lanza un cuadro de mando digital para regularizar notificaciones de brechas	Estadísticas de brechas	Administración	Cerrado oficialmente	Usar el dashboard para brechas
2026-03-03	Encargado comprometido	Alta	El informe mensual de la AEPD advierte de brechas de seguridad en la sanidad	Información de comunicaciones de la sanidad	Sanidad	Cerrado oficialmente	Revisar la seguridad de los datos, flujos de datos
2026-01-14	Brecha de seguridad + sancion	Alta	La CNIL sanciona a FREE MOBILE y FREE por violación de la seguridad de los datos	Datos personales de usuarios de FREE	Telecomunicaciones	Cerrado oficialmente	Reforzar MFA, privilegios de acceso
2026-01-13	Acceso no autorizado	Alta	INCIBE informa de la filtración comunicada por el cliente de la información de los clientes	Datos personales de clientes de SNI, Energía e IBAN	Telecomunicaciones	Cerrado oficialmente	Reforzar antifraude, avisar a clientes

Novedades Legales y Regulatorias

Fecha	Titular	Fuente	Impacto	Recomendacion
2026-04-30	AEPD publica nueva herramienta interactiva de AEPDhas	AEPD	Alto	Comparar patrones sectoriales y revisar severidad, origen y medidas de mitigación
2026-04-28	STS 1590/2026 amplía el momento en que empiezan a aplicarse las normas de protección de datos	AEPD, Tribunal Supremo	Alto	Asegurar licitud, minimización e información antes de pedir el consentimiento
2026-04-16	EDPB abre consulta pública de las Guidelines EDPB sobre investigación científica	EDPB	Alto	Revisar bases jurídicas, compatibilidad de finalidades y derechos de los interesados
2026-03-19	CEF 2026 centrado en transparencia e información	EDPB, Bajo RGP	Critico	Priorizar la revisión de artículos 12, 13 y 14 RGPD y el lenguaje de consentimiento
2026-03-25	AEPD publica su Plan de Actuación 2026	AEPD	Medio-Alto	Alinear la hoja de cumplimiento con los ejes de supervisión, innovación y transparencia
2026-02-18	AEPD publica orientaciones sobre IA agéntica	AEPD, protección de datos	Alto	Exigir DPIA, controles de autonomía, logging y restricciones sobre el uso de datos

Sanciones y Resoluciones

South Staffordshire Plc / South Staffordshire Water Plc ICO 2026-05-11
Motivo: Fallos de seguridad y brecha con publicacion en dark web
Importe: GBP 963.900
Leccion aprendida: La permanencia del atacante y la deteccion tardia multiplican el impacto regulatorio.
Accion preventiva: Mejorar deteccion, hardening y gobierno de terceros.

FREE MOBILE / FREE CNIL 2026-01-14
Motivo: Seguridad insuficiente y obligacion de notificar a afectados
Importe: EUR 42.000.000
Leccion aprendida: La mala higiene de seguridad y la afectacion de datos financieros elevan la sancion.
Accion preventiva: Asegurar autenticacion reforzada, inventario de accesos y planes de comunicacion.

Panorama AEPD 2025 AEPD 2026-05-09
Motivo: Memoria anual con fuerte peso de quiebras de seguridad
Importe: EUR 19.836.603 en procedimientos relevantes por brechas durante 2025
Leccion aprendida: Brechas y seguridad siguen entre las fuentes de mayor importe sancionador.
Accion preventiva: Revisar art. 32, 33 y 34 RGPD y pruebas de diligencia.

Derechos, DPIA, Transferencias y Cookies

Derechos de los interesados Acceso: Riesgo medio Supresion: Riesgo medio Decisiones automatizadas: Riesgo alto si hay IA o scoring Plazos: Reforzar control La principal exposicion visible para hoy es la transparencia previa y la capacidad de explicar el tratamiento de forma comprensible.	DPIA Estimacion alta en organizaciones con IA, salud, geolocalizacion o videovigilancia avanzada Prioridades - IA generativa y agentica - Analitica avanzada con datos de clientes - Movilidad y localizacion - Plataformas cloud con multiples subencargados
Transferencias internacionales Riesgo medio-alto cuando intervienen proveedores SaaS o IA de terceros - Inventariar proveedores con acceso a datos - Confirmar base de transferencia y medidas suplementarias - Revisar subencargados y logs de acceso	Cookies y consentimiento Validar consentimiento previo, opcion rechazar equivalente y bloqueo real antes del consentimiento. Encargados Alta prioridad hoy por el patron de brecha en encargados destacado por la AEPD.

Recomendaciones Clave y Alertas Activas

Recomendaciones Crítica: Revisar hoy las capas informativas - Validar artículos 12, 13 y 14 RGPD en web, formularios, onboarding, RRHH y proveedores. Crítica: Cerrar el circuito de brechas con encargados - Asegurar SLA, escalado, notificación delegada y comunicación a afectados cuando proceda. Alta: Actualizar inventario de proveedores con acceso a datos - Confirmar subencargados, transferencias y medidas técnicas reales. Alta: Lanzar o revalidar DPIA en IA y analítica avanzada - Especialmente si existe autonomía, perfilado, biometría o datos de salud. Alta: Revisar configuraciones por defecto - Minimización, retención, accesos y visibilidad por roles. Media: Comprobar cookies y terceros - Bloqueo previo, rechazo equivalente y trazabilidad del consentimiento. Media: Ejecutar microformación antifraude - Phishing, BCC, suplantación y uso seguro de herramientas de IA. Baja: Preparar observaciones a consultas europeas - Valorar si procede seguimiento interno de las Guidelines 1/2026 del EDPB.	Alertas activas - CEF 2026 sobre transparencia: prioridad máxima para informativas y deber de informar. - La AEPD subraya el riesgo de brecha en un solo encargado con afectación multi-cliente. - Las brechas con datos financieros, de salud o categorías especiales mantienen riesgo sancionador elevado. - IA agéntica y deepfakes elevan el nivel de exigencia en DPIA, control de finalidad y gobierno del dato. - Pymes españolas con proveedores cloud o marketing intensivo deben revisar transferencias y cookies.
Sección IA Riesgo estimado: 63/100 Prioridad: Alta Urgencia: Alta Impacto: Riesgo reputacional, reclamaciones, costes de respuesta y tensión contractual con clientes. Concentrar esfuerzos del día en transparencia, proveedores y protocolos de brecha.	Tendencias analíticas - Mayor escrutinio sobre informativas y deber de informar en 2026. - Más atención a IA aplicada y a cadenas de subencargados. - Sanciones con fuerte componente de seguridad, detección y comunicación a afectados. Las tendencias son una predicción analítica y no deben interpretarse como hechos confirmados.

Fuentes principales

- [AEPD - Nueva herramienta interactiva para consultar las notificaciones de brechas de datos personales \(2026-04-30\)](#)
- [AEPD - Informe de brechas marzo 2026 \(2026-04\)](#)
- [AEPD - Plan de Actuación 2026 e informe de cumplimiento 2025 \(2026-03-25\)](#)
- [AEPD - STS 1590/2026 y comienzo del tratamiento de datos \(2026-04-28\)](#)
- [EDPB - CEF 2026 sobre transparencia e información \(2026-03-19\)](#)
- [EDPB - Guidelines 1/2026 sobre investigación científica \(2026-04-16\)](#)
- [EDPB - Annual Report 2025 \(2026-04-09\)](#)
- [EDPB - Connected vehicles and mobility data summary \(2026-05\)](#)
- [AEPD - Orientaciones sobre IA agéntica \(2026-02-18\)](#)
- [ICO - Fine of nearly GBP1m issued against South Staffordshire \(2026-05-11\)](#)
- [CNIL - Data breach: FREE MOBILE and FREE fined EUR42 million \(2026-01-14\)](#)
- [INCIBE - Endesa notifica a sus clientes una filtración de datos personales \(2026-01-13\)](#)
- [AEPD - Memoria 2025 \(2026-05\)](#)

Este informe ha sido generado automáticamente mediante sistemas avanzados de inteligencia artificial y análisis de datos, tiene finalidad informativa y no constituye asesoramiento jurídico, auditoría RGPD ni dictamen legal profesional.

MMarco Seguridad | <https://mmarcoseguridad.com> | mmarco.seguridad@gmail.com | +34 656 33 93 55